

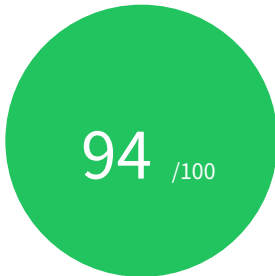
網站安全掃描報告

由 Risk Sentinel 生成

掃描時間: 2026/2/20 上午3:50:38

目標網址: <https://humanities-ai-lab.github.io/tomorrow-history-studio/>

整體安全分數



分數細項

Headers	60	TLS/SSL	100	DNS	100
Cookies	100	內容	100	曝露	100

問題嚴重程度統計



風險評估

處理優先級

立即修復: 0

盡快修復: 5

持續監控: 5

商業風險分析

資料外洩風險	0%	用戶入侵風險	0%
財務損失風險	0%	聲譽損害風險	30%

詳細發現 (10)

HIGH

缺少 CSP Header

類別: HTTP Security Headers

檢測結果

Content-Security-Policy header not found

風險說明

網站容易遭受 XSS 攻擊。

修復建議

Content-Security-Policy: default-src 'self'; script-src 'self'

詳細發現 (第 2)

HIGH

缺少 HSTS Header

類別: HTTP Security Headers

檢測結果

Strict-Transport-Security header not found

風險說明

使用者可能被降級到 HTTP 連線，遭受中間人攻擊。

修復建議

Strict-Transport-Security: max-age=31536000; includeSubDomains; preload

MEDIUM

缺少 Clickjacking 保護

類別: HTTP Security Headers

檢測結果

X-Frame-Options 和 frame-ancestors 都未設定 (found on 2 pages)

風險說明

網站可能被嵌入惡意 iframe。

修復建議

X-Frame-Options: DENY 或 CSP frame-ancestors

MEDIUM

CORS 使用通配符

類別: CORS Security

檢測結果

Access-Control-Allow-Origin: *

風險說明

任何網站都可存取此 API。

修復建議

限制允許的 Origin 清單。

MEDIUM

CSP 設定過於寬鬆

類別: HTTP Security Headers

檢測結果

unsafe-inline 未配合 nonce/hash; 使用 unsafe-eval

風險說明

降低了 CSP 的防護效果。

修復建議

移除 unsafe-inline/unsafe-eval，使用 nonce 或 hash。

詳細發現 (第 3)

LOW

缺少 X-Content-Type-Options

類別: HTTP Security Headers

檢測結果

X-Content-Type-Options: nosniff not set (found on 2 pages)

風險說明

瀏覽器可能錯誤解析檔案類型。

修復建議

X-Content-Type-Options: nosniff

LOW

Server 版本資訊外洩

類別: Information Disclosure

檢測結果

Server: GitHub.com (found on 2 pages)

風險說明

攻擊者可針對特定版本漏洞進行攻擊。

修復建議

移除 Server header 中的版本資訊。

INFO

HTTPS 已啟用

類別: TLS / Certificate

檢測結果

HTTPS connection successful

風險說明

傳輸資料已加密。

修復建議

無需修改。

INFO

未設定 Cookie

類別: Cookies

檢測結果

No Set-Cookie headers (found on 2 pages)

風險說明

此頁面未設定 Cookie。

修復建議

無需修改。

詳細發現 (第 4)

INFO

XSS Scan Complete

類別: XSS Vulnerability

檢測結果

Tested common reflection points. (found on 2 pages)

風險說明

No obvious XSS vulnerabilities detected in basic testing.

修復建議

Continue implementing security best practices.